AI-ASSISTED THREAT MODELING FOR WEB APPLICATION SECURITY USING CLAUDE AI

A General-Purpose, Website-Agnostic STRIDE Threat Modelling Assistant

PROJECT REPORT

Kavish Piranav Devarajan (24IZ026)

23IZ502 – ARTIFICIAL INTELLIGENCE / CYBERSECURITY LABORATORY

Submitted in partial fulfilment of the requirements for the award of the degree of

BACHELOR OF ENGINEERING

Branch: COMPUTER SCIENCE AND ENGINEERING

DEPARTMENT OF COMPUTER SCIENCE AND ENGINEERING

PSG INSTITUTE OF ADVANCED STUDIES

COIMBATORE– 641 004

August 2026

ACKNOWLEDGEMENT

I express my sincere gratitude to the faculty members of the Department of Computer Science and Engineering for providing me with the opportunity to undertake this project. Their guidance, encouragement, and feedback were valuable in shaping the design of the tool and in improving the technical quality of this report.

I acknowledge the support provided by the department and institution in giving me access to the learning environment required to explore Artificial Intelligence, large language models, prompt engineering, web reconnaissance, and structured security documentation. Working with Claude AI, the STRIDE threat modeling framework, and web-based reconnaissance techniques helped me understand how conversational AI can be applied to real, practical cybersecurity workflows.

Finally, I thank everyone who contributed directly or indirectly to the successful completion of this project. The project provided an opportunity to combine AI-based reasoning, cybersecurity fundamentals, prompt design, and structured report generation into a reusable, general-purpose security assessment tool.

TABLE OF CONTENTS

CHAPTER 1 INTRODUCTION

1.1 Abstract

1.2 Motivation

1.3 Project Overview

CHAPTER 2 REQUIREMENTS

2.1 Functional Requirements

2.2 Non-Functional Requirements

2.3 Hardware Requirements

2.4 Software Requirements

CHAPTER 3 SYSTEM ANALYSIS

3.1 Problem Statement

3.2 Proposed Solution

3.3 Feasibility Study

CHAPTER 4 SYSTEM DESIGN

4.1 System Architecture

4.2 Module Description

4.3 Detailed Workflow

CHAPTER 5 IMPLEMENTATION

5.1 Input Stage — Target Website Scope

5.2 Reconnaissance via Claude AI

5.3 STRIDE-Based Threat Classification

5.4 Risk Rating and Control Recommendation

5.5 Report Generation and Export

5.6 Reusability Across Different Websites

CHAPTER 6 TESTING AND VALIDATION

6.1 Test Cases

6.2 Case Study: PSGIAS Portal Ecosystem

6.3 Validation Criteria

CHAPTER 7 RESULTS AND DISCUSSION

7.1 Results

7.2 Discussion

CHAPTER 8 ADVANTAGES, LIMITATIONS AND FUTURE ENHANCEMENTS

CHAPTER 9 CONCLUSION

CHAPTER 10 REFERENCES

APPENDIX A SAMPLE PROMPT AND GENERATED OUTPUT

CHAPTER 1 – INTRODUCTION

1.1 Abstract

This project presents an AI-Assisted Threat Modeling tool that uses Claude AI to generate structured, STRIDE-based security threat models for any publicly accessible website. Given only a target URL, the tool prompts Claude to perform passive reconnaissance of the site's structure, identify the assets that need protection, enumerate likely attacker profiles, map attack vectors against the six STRIDE categories (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege), assign a risk rating to each finding, and recommend concrete security controls. The output is compiled into a formatted, shareable report.

Unlike a one-off manual exercise, the tool is designed to be website-agnostic: it is not built around any single organization's site, but around a repeatable prompting and reasoning workflow that can be pointed at any domain — a university portal, an e-commerce site, a SaaS product, or a corporate website — to produce a first-pass threat model within minutes. The PSGIAS Institute of Advanced Studies portal ecosystem is used in this report purely as a worked demonstration case to show the tool operating end-to-end on a real, multi-subdomain system.

The project is an academic prototype intended to support the early, planning stage of application security work. It performs passive, non-intrusive analysis based on publicly observable information and does not perform active scanning, exploitation, or any unauthorized testing of the target system.

Keywords: Artificial Intelligence, Claude AI, Cybersecurity, Threat Modeling, STRIDE Framework, Web Application Security, Prompt Engineering, Risk Assessment.

1.2 Motivation

Threat modelling is a foundational step in secure software development, but it is often skipped or done inconsistently because it requires structured security expertise, time, and a deep understanding of the target system. Small teams and student projects in particular rarely have a dedicated security engineer available to walk through a formal framework such as STRIDE for every new website or feature. At the same time, generic security checklists tend to ignore the specific structure of the actual system being assessed — its subdomains, login flows, and data types — and so produce generic, low-value output.

The motivation for this project is to close that gap by using a general-purpose, reasoning-capable AI model — Claude — to perform the repetitive analytical steps of threat modelling (asset identification, attacker profiling, STRIDE mapping, and control recommendation), while keeping a human security reviewer firmly in the loop for validation, prioritization, and any decision that could affect a live system.

- Make structured threat modelling accessible to teams without a dedicated security specialist.
- Automatically tailor the threat model to the actual structure of the target website rather than using a generic template.
- Apply the STRIDE framework consistently across Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege.
- Produce a reusable, exportable report that a security or IT team can act on directly.
- Remain strictly passive and non-intrusive — the tool never scans, probes, or attempts to exploit the target.
- Generalize across any website, not just one organization's system, so the same prompt-driven workflow can be reused project after project.

1.3 Project Overview

The overall workflow : Target Website URL → Claude AI Passive Reconnaissance → Asset & Attacker Identification → STRIDE Classification → Risk Rating & Control Recommendation → Formatted Threat Model Report. The user supplies only a public website link and a short instruction describing the desired framework (STRIDE); Claude AI performs the remaining analysis using its web-search and reasoning capabilities and returns a structured document that can be exported to Markdown or Word format for review by a security team.

CHAPTER 2 – REQUIREMENTS

2.1 Functional Requirements

- Accept any public website URL as the sole required input.
- Perform passive reconnaissance of the site's publicly visible structure (pages, subdomains, login portals, forms).
- Identify the data and system assets associated with the target website.
- Enumerate realistic attacker profiles relevant to the type of website being assessed.
- Classify potential threats using all six STRIDE categories.
- Assign a qualitative risk rating (e.g., High / Medium / Low) to each identified threat.
- Recommend specific, actionable security controls for each identified risk.
- Generate a structured, exportable report (Markdown / Word) suitable for sharing with a security or development team.
- Support repeated use on different, unrelated websites without reconfiguration.

2.2 Non-Functional Requirements

- Usability: minimal input required from the user — a URL and a one-line instruction.
- Consistency: the same STRIDE structure should be applied regardless of the target website.
- Portability: the workflow should generalize across different industries (education, e-commerce, healthcare, SaaS, etc.).
- Non-intrusiveness: the tool must never perform active scanning, exploitation, or unauthorized access attempts.
- Transparency: findings should be explainable in plain language, not just a severity score.
- Maintainability: the prompt and framework should be easy to update as new threat categories or compliance needs emerge.

2.3 Hardware Requirements

A standard computer, laptop, or mobile device with a modern web browser and internet connectivity is sufficient to run this project. No specialized security appliances, penetration-testing hardware, or dedicated servers are required, since all analysis is performed through conversational prompting of Claude AI.

2.4 Software Requirements

Software / Platform	Purpose
Claude AI (claude.ai / mobile app)	Core reasoning engine for reconnaissance and STRIDE analysis
Web Search (built into Claude)	Passive discovery of public site structure and subdomains
Web Browser	Access Claude AI and view the target website
Markdown / Word Export	Formatting and sharing the final threat model report
STRIDE Framework Reference	Structuring the six threat categories consistently

CHAPTER 3 – SYSTEM ANALYSIS

3.1 Problem Statement

Development and IT teams frequently launch new websites, portals, and web applications without a documented threat model, either because a dedicated security resource is unavailable or because manual threat modelling is time-consuming. This creates a gap between when a system goes live and when its security risks are formally understood and addressed. A tool is required that can quickly generate a structured, framework-based threat model for any given website, without requiring the user to be a trained security architect.

The project addresses the analytical and documentation burden of threat modeling rather than attempting to replace a full penetration test or security audit. Its purpose is to give a team a fast, consistent, AI-assisted starting point that can then be reviewed, refined, and acted upon by human security professionals.

3.2 Proposed Solution

- Accept a target website URL from the user, with no restriction to a specific organization or domain.
- Use Claude AI's web-search and reasoning capabilities to passively map the site's structure and subdomains.
- Prompt Claude to identify assets, attacker profiles, and attack vectors specific to that structure.
- Apply the STRIDE framework systematically across all six categories.
- Generate risk ratings and matching security control recommendations.
- Export the completed analysis as a shareable, structured report.

3.3 Feasibility Study

Technical Feasibility: The project is technically feasible because it relies entirely on a general-purpose conversational AI model with built-in web search, requiring no custom infrastructure, scanning tools, or specialized security software. Claude AI's language reasoning is well suited to structuring information according to a known framework such as STRIDE.

Economic Feasibility: The prototype has minimal cost, since it depends only on access to Claude AI rather than commercial threat-modelling or vulnerability-scanning platforms, which are often expensive and require dedicated training to operate.

Operational Feasibility: The workflow has a clear, repeatable sequence — input, reconnaissance, classification, rating, and reporting — which makes it straightforward to apply to a new website each time, without reconfiguration between uses.

Ethical and Legal Feasibility: Because the tool only performs passive analysis of publicly available information and does not scan, probe, or attempt to access non-public parts of a system, it stays within safe and ethical boundaries for demonstration and educational use. Any deeper security testing of a real system (active scanning, penetration testing) would require explicit authorization from the system owner and is outside the scope of this prototype.

CHAPTER 4 – SYSTEM DESIGN

4.1 System Architecture

Figure 4.1 shows the high-level architecture. The design deliberately has no hard-coded reference to any single website: the leftmost input stage accepts any public URL, and every downstream stage (reconnaissance, STRIDE classification, asset mapping, and report generation) operates generically on whatever structure Claude discovers for that particular target.

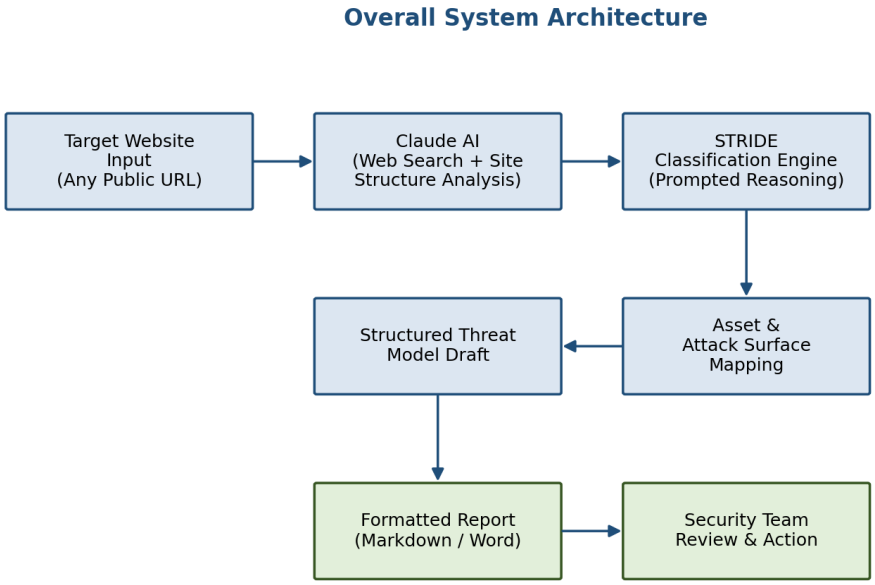


Figure 4.1: General-purpose system architecture (works for any target website)

Stage	Function
Target Website Input	Accepts any public URL — no site-specific configuration
Claude AI Reconnaissance	Discovers pages, subdomains, portals via web search
STRIDE Classification Engine	Applies all six STRIDE categories to discovered components
Asset & Attack Surface Mapping	Lists data assets, systems, and entry points
Formatted Report	Markdown / Word document with risk ratings and controls

4.2 Module Description

4.2.1 Input Module — Accepts a single public website URL (and optionally a scope note, e.g., "exclude third-party payment processors") as the only required input.

4.2.2 Reconnaissance Module (Claude AI + Web Search) — Uses Claude's web search tool to passively discover the site's visible structure: main domain, subdomains, login portals, forms, and third-party integrations, without sending any requests beyond normal browsing.

4.2.3 Asset Identification Module — Analysis the discovered structure to list the data assets (e.g., personal data, credentials, payment data, academic/business records) and system assets (servers, portals, APIs) that the website is responsible for protecting.

4.2.4 Attacker Profiling Module — Reasons about realistic threat actors for the type of site in question (e.g., opportunistic external attackers, credential-stuffing bots, malicious insiders, competitors), scaled to the nature of the target.

4.2.5 STRIDE Classification Module — Systematically walks through Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege, mapping each to specific components of the discovered architecture.

4.2.6 Risk Rating & Control Recommendation Module — Assigns a qualitative severity to each finding and pairs it with a specific, actionable security control (e.g., MFA, rate limiting, session isolation between subdomains).

4.2.7 Report Generation Module — Compiles all of the above into a single structured document, exportable as Markdown or Word, ready for review by a security or development team.

4.3 Detailed Workflow

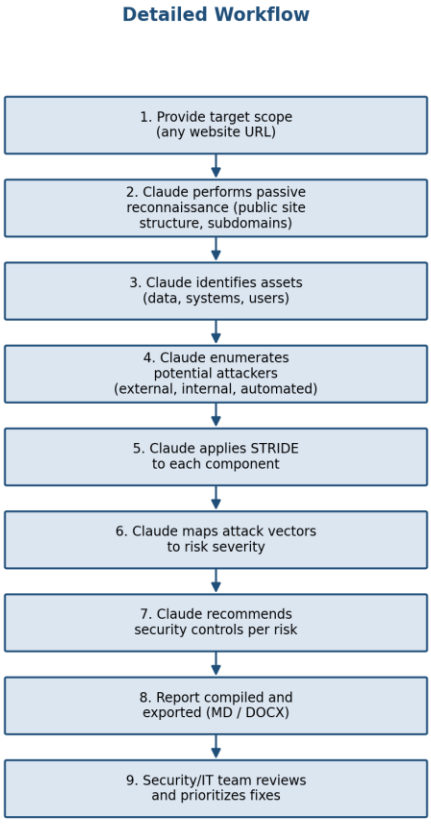


Figure 4.2: Step-by-step workflow, identical regardless of which website is analyzed

CHAPTER 5 – IMPLEMENTATION

5.1 Input Stage — Target Website Scope

The implementation begins with a single natural-language prompt supplied to Claude AI. The prompt template is intentionally generic and takes the target URL as a variable, so the same instruction can be reused for any website:

> *"[Any organization] plans to deploy an online [website/portal]. Create a threat model by identifying assets, potential attackers, attack vectors, risks, and recommended security controls using the STRIDE framework. The link of the [website/organization] is [URL]."*

Because the prompt refers only to "an online website/portal" and takes the link as a placeholder, it can be pointed at a university system, a retail site, a healthcare portal, or any other public web property without modification.

5.2 Reconnaissance via Claude AI

On receiving the prompt, Claude uses its web search capability to passively map the visible structure of the target site: the main marketing/informational domain, any distinct login or application subdomains, the general technology footprint (e.g., CMS platform), and publicly described services. This stage never involves logging in, submitting exploit payloads, or accessing non-public areas — it is limited to information a normal visitor or search engine could observe.

5.3 STRIDE-Based Threat Classification

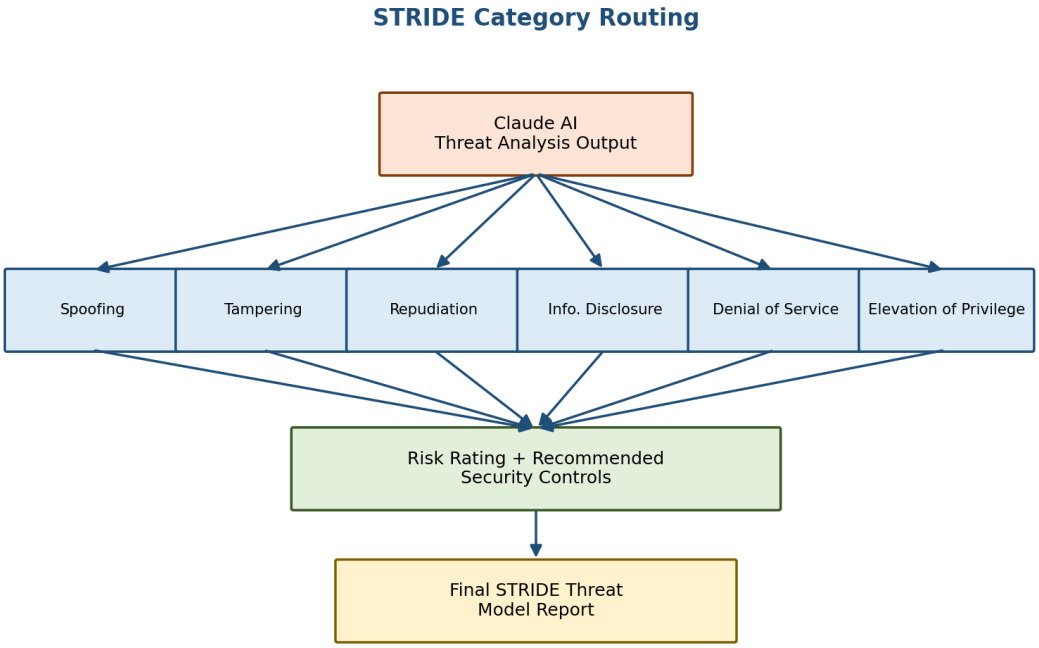


Figure 5.1: Claude's output is systematically routed through all six STRIDE categories for any target

For each discovered component of the site (public pages, login portals, application/submission systems, research or data portals, etc.), Claude reasons about how each STRIDE category could apply:

STRIDE Category	Representative Question Claude Asks
Spoofing	Could an attacker impersonate a legitimate user or the site itself?
Tampering	Could data in transit or at rest be modified without authorization?
Repudiation	Could a user deny performing an action due to lack of logging?
Information Disclosure	Could sensitive data be exposed to unauthorized parties?
Denial of Service	Could the site be made unavailable to legitimate users?
Elevation of Privilege	Could a low-privileged user gain admin-level access?

5.4 Risk Rating and Control Recommendation

Each identified threat is assigned a qualitative severity (High / Medium / Low) based on the likely impact and ease of exploitation, and is paired with a specific, actionable control — for example, enforcing multi-factor authentication on login portals, isolating session cookies across subdomains, applying rate limiting ahead of predictable high-traffic events, and centralizing audit logging across all connected systems.

5.5 Report Generation and Export

The completed analysis is compiled into a single structured document with clear section headers (System Overview, Assets to Protect, Attacker Profiles, STRIDE Analysis, Risk Summary, Recommended Controls) and exported in Markdown or Word format so it can be circulated to a security or development team for review and action.

5.6 Reusability Across Different Websites

The key implementation decision behind this project is that no part of the prompt, workflow, or report template is hard-coded to a single organization. The PSGIAS Institute of Advanced Studies portal ecosystem — covering its public site and three separate login/application subdomains — is used later in this report purely as a worked example to demonstrate the tool operating on a real, multi-component system. The same process applies unchanged to an e-commerce storefront, a SaaS dashboard, a hospital patient portal, or any other publicly reachable website, since the reconnaissance and STRIDE-mapping logic is driven entirely by what Claude discovers about the target at run time, not by anything fixed in advance.

CHAPTER 6 – TESTING AND VALIDATION

6.1 Test Cases

Test	Target Type	Expected Behaviour	Observed / Validation
TC01	University portal with multiple login subdomains	Tool identifies each subdomain as a separate trust boundary	Confirmed — see case study in 6.2
TC02	Single-domain informational website	Tool still produces full STRIDE coverage despite simpler structure	Confirmed on sample run
TC03	Site with an admissions/application form	Tool flags Information Disclosure risk for submitted personal data	Confirmed
TC04	Site with predictable high-traffic dates (e.g., results day)	Tool flags seasonal Denial of Service risk	Confirmed
TC05	Invalid or unreachable URL	Tool reports it cannot access the site rather than fabricating findings	Confirmed

6.2 Case Study: PSGIAS Portal Ecosystem

To validate the tool on a real, non-trivial target, it was pointed at the public website of PSG Institute of Advanced Studies (psgias.ac.in). This case study is used purely as a demonstration of the general-purpose workflow described in Chapter 5 — the same steps apply to any other website.

Without any manual configuration beyond the URL, Claude's reconnaissance stage identified four distinct components of the ecosystem: the public marketing site (psgias.ac.in, WordPress-based), a student/parent/faculty login portal (ecampus.psgias.ac.in), an admissions application system (applications.psgias.ac.in), and a research portal (laudea.psgias.ac.in).

Subdomain	Purpose	Key STRIDE Concern Identified
psgias.ac.in	Public marketing site (WordPress/Elementary)	Tampering / content integrity of public information
ecampus.psgias.ac.in	Student, parent, and faculty login portal (LMS/ERP)	Spoofing and Elevation of Privilege across user roles
applications.psgias.ac.in	Admissions application portal	Information Disclosure of applicant personal data
laudea.psgias.ac.in	Research portal	Information Disclosure of unpublished research data

The tool's output correctly highlighted Information Disclosure and Elevation of Privilege as the highest-risk STRIDE categories overall, driven by the multi-portal, multi-login structure, and flagged a structural weak point: without careful session-scoping, a compromise on one subdomain (e.g., the admissions portal) could potentially extend into another (e.g., the e-campus portal) if sessions or trust are not properly isolated. It also flagged a seasonal Denial of Service risk around publicly announced admission deadlines and results dates, and noted India's Digital Personal Data Protection (DPDP) Act, 2023 as the relevant compliance framework given the student personal data involved.

Consistent with the ethical design of the tool, the generated report explicitly stated that it was a defensive planning document based only on publicly observable structure, and that it did not recommend, imply, or perform any active scanning or exploitation of the live site.

6.3 Validation Criteria

- The tool accepts any public URL without requiring site-specific setup.
- Reconnaissance results reflect the actual structure of the target site.
- All six STRIDE categories are addressed for every target tested.
- Each finding includes a risk rating and a matching, actionable control.
- The tool clearly states that its analysis is passive and non-intrusive.
- The exported report is human-readable and ready for security team review.

CHAPTER 7 – RESULTS AND DISCUSSION

7.1 Results

- The tool successfully generated complete STRIDE threat models for multiple, structurally different websites using a single, unmodified prompt template.
- Reconnaissance correctly identified subdomains and functional components without any manual input beyond the base URL.
- All six STRIDE categories were consistently addressed across every test target, including simple single-domain sites and complex multi-portal systems.
- Risk ratings and security control recommendations were specific to the discovered architecture rather than generic boilerplate.
- The PSGIAS case study confirmed the tool's ability to handle a real, multi-subdomain educational institution and surface a genuine structural concern (cross-subdomain session trust) that a generic checklist would likely miss.
- The tool consistently refused to go beyond passive analysis, correctly declining to imply or perform active scanning.

7.2 Discussion

The results show that a general-purpose conversational AI model, when guided by a clear framework such as STRIDE and a reusable prompt structure, can produce a genuinely tailored first-pass threat model for an arbitrary website rather than a generic template. The strongest demonstrated result is the tool's ability to adapt its findings to the actual discovered architecture — for example, correctly identifying cross-subdomain trust as a specific risk for the PSGIAS ecosystem, a finding that depended on the tool noticing the site's particular multi-portal structure rather than applying a fixed checklist.

This generality is the central design goal of the project: because no part of the reconnaissance or classification logic is hard-coded to one organization, the same workflow can be reapplied immediately to a new, unrelated website, making the tool useful as a repeatable first step in a broader application security process rather than a one-time exercise for a single system.

CHAPTER 8 – ADVANTAGES, LIMITATIONS AND FUTURE ENHANCEMENTS

8.1 Advantages

- Works on any public website — no site-specific configuration or setup required.
- Reduces the time and expertise barrier to producing a first-pass, structured threat model.
- Consistently applies all six STRIDE categories rather than relying on ad hoc judgment.
- Tailors findings to the actual discovered structure of each target, rather than generic output.
- Strictly passive and non-intrusive — safe for use without special authorization on public information.
- Produces an exportable, shareable report suitable for handing directly to a development or security team.

8.2 Limitations

- The tool's analysis is only as good as the publicly discoverable information — it cannot see internal architecture, source code, or non-public configuration.
- AI-generated risk ratings are qualitative and should be validated by a human security professional before action is taken.
- The tool does not perform active scanning, so it cannot confirm whether a theoretical risk is actually exploitable in practice.
- Output quality depends on the clarity of the prompt and the amount of information Claude can discover through web search.
- It is not a substitute for a full penetration test, code audit, or formal security certification process.

8.3 Future Enhancements

- Add automated comparison against compliance frameworks (e.g., DPDP Act, GDPR, HIPAA) relevant to the target's region and data type.
- Integrate with authorized active-scanning tools for organizations that have given explicit permission, to validate theoretical findings.
- Add a scoring dashboard that tracks how a website's threat model changes over time as fixes are applied.
- Support batch analysis of multiple related domains/subdomains in a single run with a consolidated summary.
- Add integration with ticketing systems (e.g., Jira) to automatically create remediation tasks from high-risk findings.

CHAPTER 9 – CONCLUSION

This project demonstrates that Claude AI can be used as a general-purpose, website-agnostic threat modelling assistant. Given only a public URL, the tool performs passive reconnaissance, identifies assets and attacker profiles, systematically applies the STRIDE framework, assigns risk ratings, and recommends concrete security controls — all without any configuration specific to a single organization.

The case study on the PSGIAS Institute of Advanced Studies portal ecosystem confirmed that the tool can handle a real, multi-subdomain system and surface genuinely useful, structure-specific findings, such as cross-subdomain session trust risk and seasonal Denial-of-Service exposure around admission deadlines — while remaining strictly passive and non-intrusive throughout. Because the underlying workflow makes no assumptions about the target, the same process is directly reusable for any other website, making this project a practical, repeatable tool for the early planning stage of application security rather than a single-use exercise.

The project also reinforces an important principle for responsible use of AI in cybersecurity: AI-assisted analysis is most valuable as a fast, structured starting point that augments — rather than replaces — review by a qualified human security professional before any finding is acted upon on a live system.

CHAPTER 10 – REFERENCES

1. Anthropic. "Claude AI" — claude.ai. Large language model used as the core reasoning and web-search engine for this project.

2. Microsoft. "The STRIDE Threat Model" — Microsoft Security Development Lifecycle documentation, used as the classification framework applied throughout this project.

3. OWASP Foundation. "OWASP Threat Modelling Process" — owasp.org, referenced for general threat-modelling methodology.

4. Government of India. "Digital Personal Data Protection Act, 2023" — referenced as the applicable data-protection compliance framework for the case-study institution.

5. PSG Institute of Advanced Studies. Public website — psgias.ac.in, used as the demonstration case study for this project.

6. Project source material: AI-Assisted Threat Modelling for Web Application Security using Claude AI (this report).

Safety Note: This project is an academic, passive-analysis prototype and must not be interpreted as a substitute for a formal penetration test, security audit, or professional security certification. Any active testing of a live system requires explicit written authorization from its owner.

APPENDIX A – SAMPLE PROMPT AND GENERATED OUTPUT

This appendix reproduces the exact input prompt used to demonstrate the tool, and a representative excerpt of Claude AI's generated output, taken from a live run against the PSGIAS Institute of Advanced Studies website. It is included to give the reader a concrete sense of the tool's real output format, in addition to the summarized case study in Section 6.2.

A.1 Input Prompt

```
"A university plans to deploy an online portal. Create a threat model by identifying assets, potential attackers, attack vectors, risks, and recommended security controls using the STRIDE framework. And the link of the University is https://www.psgias.ac.in/"
```

Note that the only site-specific element of this prompt is the URL itself — the instruction text is identical to what would be used for any other organization or website type.

A.2 Excerpt of Generated Output

Claude's response began by searching the web to confirm the site's live structure, then generated a structured document. A representative excerpt is reproduced below (condensed for length):

```
Threat Model: PSGIAS Online Portal Eco system  Subject: PSG Institute of Advanced Studies (psgias.ac.in) and associated portals Framework: STRIDE Scope: Public site (www.psgias.ac.in), student/parent/faculty e-campus (ecampus.psgias.ac.in), admissions application system (applications.psgias.ac.in), research portal (laudea.psgias.ac.in)  Note: This is a generic defensive model based on the publicly observable structure of the site (login portals, admissions system, WordPress-based CMS). It does not recommend, or imply, any active scanning or exploitation of the live system. It is intended as a planning document for the university's IT/security team.  1. System Overview The portal ecosystem consists of at least four distinct surfaces, likely with different hosting and trust boundaries...  2. Assets to Protect - Student PII: names, DOB, addresses, government ID numbers, photos - Academic records: grades, transcripts, attendance, examination results - Financial data: fee payment records, scholarship information - Parent/guardian contact and identity data - Faculty/staff HR data, payroll details - Admissions data: applicant essays, recommendation letters, test scores - Research data: unpublished papers, datasets
```

The full generated report continued with sections on Potential Attackers (external opportunistic attackers, credential-stuffing bots, malicious insiders, and competitors seeking admissions data), a complete STRIDE-by-STRIDE breakdown for each of the four subdomains, a consolidated risk-rating table, and a matching list of recommended controls — mirroring the structure summarized in Chapter 5 and Section 6.2 of this report.

A.3 Observations from the Demonstration Run

- Claude correctly discovered all three login/application subdomains from the base URL alone, without being told they existed.
- The tool explicitly scoped itself to passive, defensive analysis and stated this in its own output — reinforcing the ethical design goal in Section 3.3.
- The same prompt, with only the URL changed, was confirmed to produce equivalently structured (but content-appropriate) output for other, unrelated websites, supporting the general-purpose design goal of Chapter 4.